[un]prompted

The AI Practitioner Conference

Your Harness Needs a Security Constitution

Kat Traxler

Cloud Security Researcher

WHAT I DID · ABOUT THREE MONTHS · THREE CLOUD PROVIDERS

What came back from the vendors

109
filed bugs
across three cloud providers

−

11
ruled working
as intended

=

98
real issues

53 accepted
accepted · rewarded · duplicates of a tracked bug

+

45 still in triage
awaiting triage · awaiting determination · in dispute

All vulnerabilities identified from inspecting public APIs and validating from live infrastructure.

TWO KINDS OF BUG

A bug in code.

SQL injection, XSS, memory corruption. These are bad lines of code which models are great at finding.

A flaw in design.

A missing authorization check. An action nobody can audit. A credential nobody can revoke.

The code is correct but the design contains a flaw.

You can only see what's missing if you know what should be there.

needs a point of view

SCOPE

This is not a talk about a bug-hunting harness.

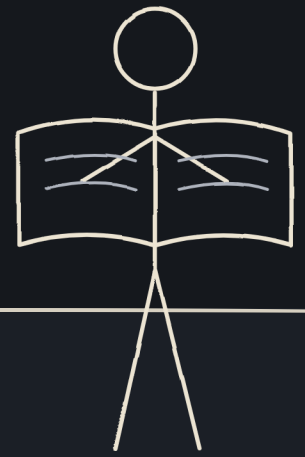
It's about novel candidate generation, using a Security Constitution as a security-alignment layer when a model evaluates an attack surface.

A security-alignment layer

Your model LLM agnostic	→	***The Security Constitution*** what the platform *should* guarantee

→ ***The attack surface***
(i.e. API specifications)

It doesn't tell the model what to do. It tells the model what should be true.



TWO WAYS TO STEER A MODEL

Prescriptive, or descriptive

Cloudflare's security-audit skill *(open-sourced, MIT)*

1. map the codebase
2. hunt area by area
3. a fresh agent confirms each finding
4. write structured results
5. verify each record again
6. write the report

Tells the agent exactly *what to do*.

The Security Constitution

Twelve principles on how trust should be held. Eleven lessons on how to be wrong less. Thirteen anchors a platform can root a decision in.

Tells the model *what security is* — and what a violation of trust looks like.

One instructs the model on how to get from point A to point B. The other expands what it can see, leaving headroom for vulnerability discovery as models improve.

WHERE IT FITS

At the top of the funnel: candidate generation

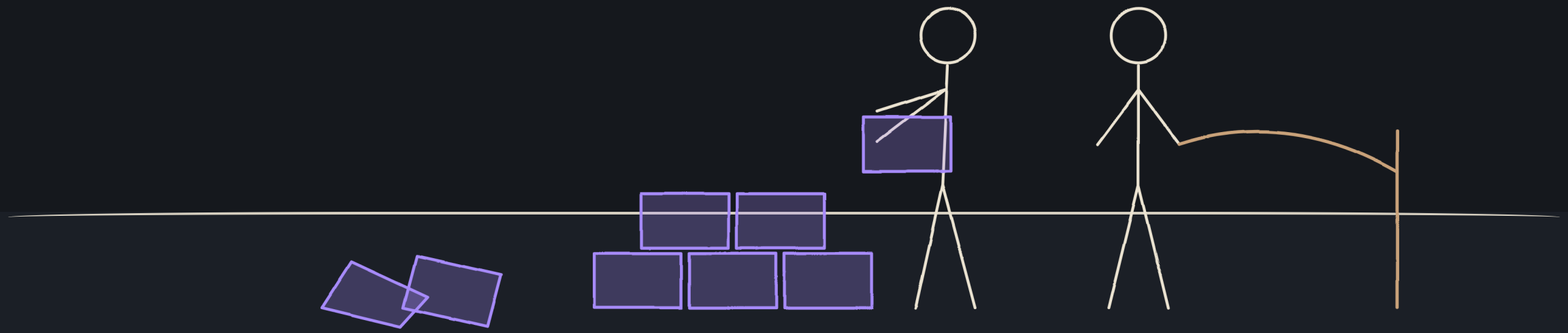


Everything to the right is ordinary plumbing. This talk is the constitution driving the funnel — with new ways of breaking the cloud.

WHAT I AM RELEASING TODAY

The Security Constitution

- 12 security principles
- 11 operational lessons
- 13 Anchors of Trust



THE SECURITY CONSTITUTION

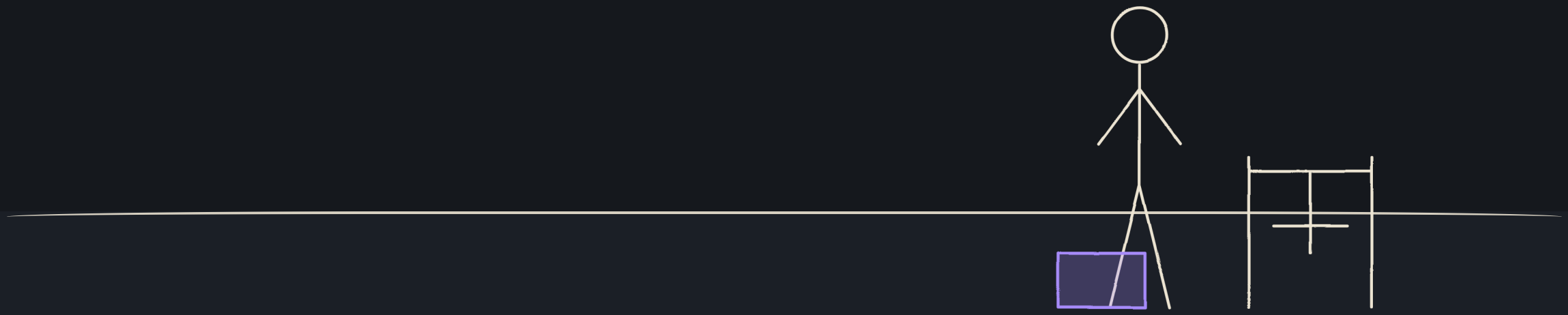
Twelve principles for how trust is held

1. Authorization at every trust boundary
2. Auditable security-relevant actions
3. Least privilege for both humans and NHIs alike
4. Customer control over risky functionality
5. Tenant isolation
6. Internal protocols held to public API standards
7. Credential lifecycle governance
8. Bounded blast radius for delegation
9. Cross-domain authority verification
10. Secret custody follows secret use
11. Network and connectivity resources are protected resources
12. Cross-service authorization completeness

PRINCIPLE 1

Authorization at every trust boundary

Every time a request changes hands — a different identity, a different system, a different tenant, a different resource, authorization should be checked again.



Vertex AI

GCP · b/516599995

fixed

THE FINDING

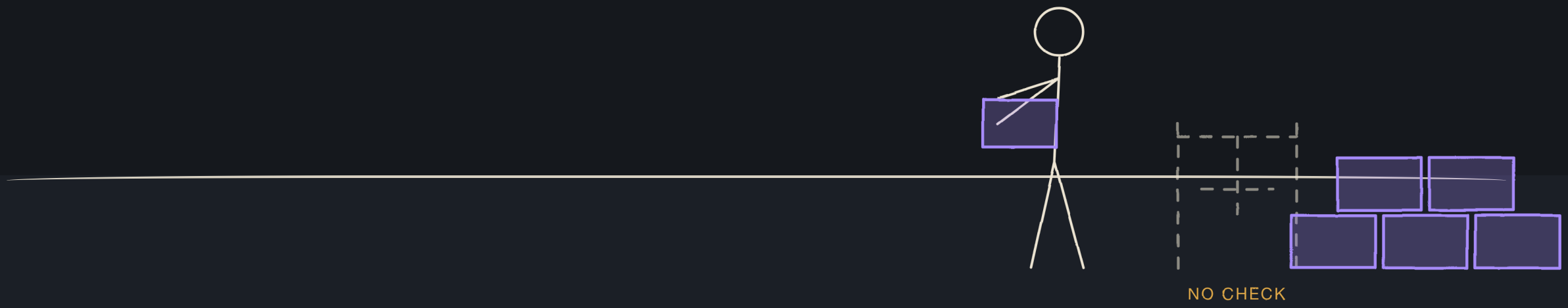
evaluateDataset

Confused Deputy allowing an ordinary Vertex user to read GCS objects they cannot access and write objects into a bucket they do not control — no caller-authz check on the input or output reference

THE SHAPE

SHAPE-001 · managed deputy r/w

- A managed identity acts on a caller-named resource with its own permissions, not the caller's
- The caller gets the effect of a permission it does not hold



WHAT PROMPTING LOOKS LIKE

```
Anchor yourself in the principles outlined in the security
constitution.

From that view of the world, review <service> and generate new
candidates to hunt for insecure-by-design flaws.
```

Input: the public API reference. Output: candidates, each tagged with the principle it would violate.

THE LOOP

10 principles grew to 12

Principles 1–10

The lessons were extracted from published design flaws and from personal experience in the cloud security space.

Principles 11 and 12

Written *after* the BigQuery Data Transfer finding.

11 A network is a protected resource too.

12 When a request crosses two services, one of them has to check the caller.



PRINCIPLES 11 AND 12

Network resources are protected resources
Cross-service authorization completeness

11 Accessing a network is a privileged act — a network the caller names must be authorized like any other resource.

12 When a request crosses two services, one of them has to own the check on the caller.



BigQuery Data Transfer Service

GCP · b/518828428

accepted

THE FINDING
transferConfigs.create

Confused Deputy flaw letting a user with one BigQuery permission read a private database in another tenant's VPC, exfiltrating the data out through BigQuery's shared transfer infrastructure

PREREQUISITES
victim side

The victim must expose a private database to BigQuery Data Transfer through a PSC network attachment set to ACCEPT_AUTOMATIC, or ACCEPT_MANUAL where one of the Google-owned shared fleet projects is allowed.

THE SHAPE
SHAPE-013 · network-attachment deputy

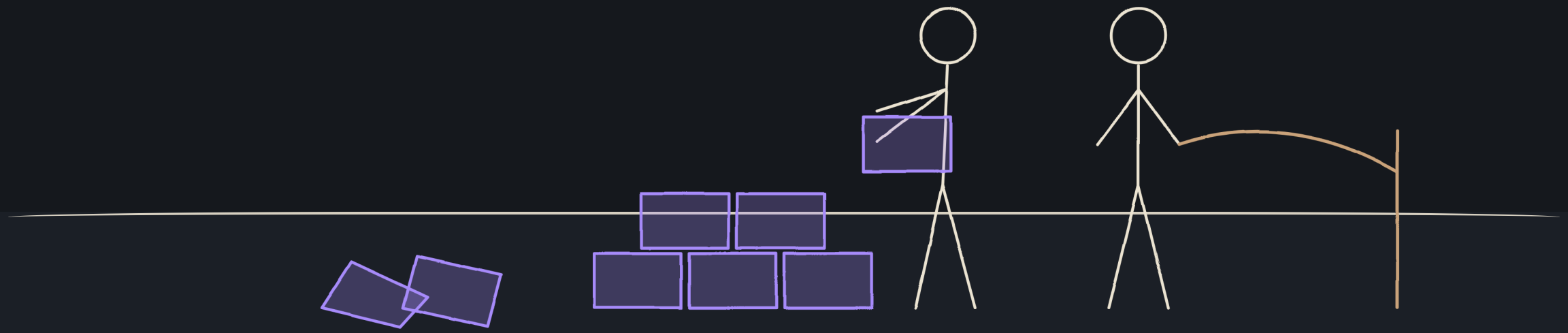
A non-human identity, acting on a network attachment the caller named, establishes presence inside a network the caller has no standing in.



PRINCIPLE 7

Credential lifecycle governance

Every long-lived credential must remain under its administrator's governance across its entire lifecycle — enumerable on demand, bounded in issuance and lifetime, and definitively revocable — so that disablement genuinely invalidates it and no durable credential survives remediation undiscovered or unrevoked.



Azure Managed Grafana

Azure · VULN-209280

fixed

THE FINDING

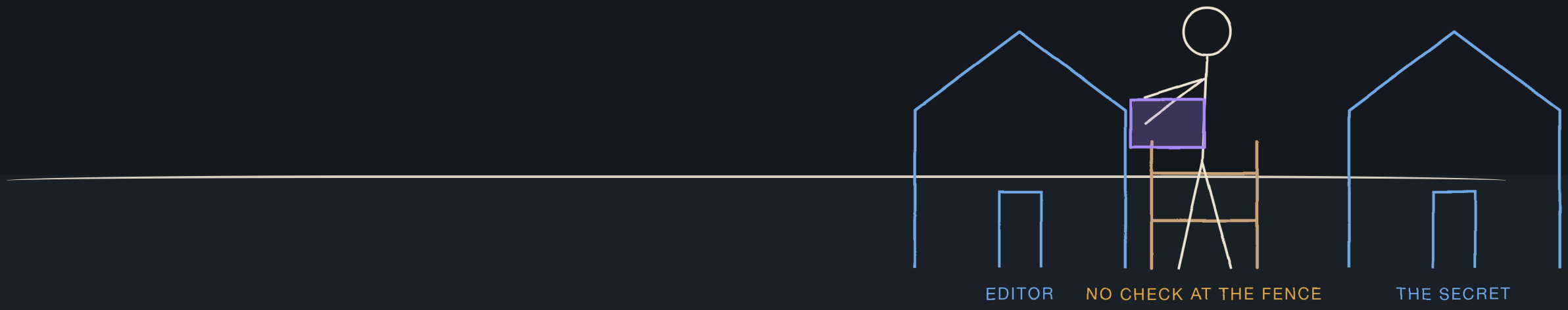
Grafana_Update · smtp.host

Credential redirect allowing an editor to receive and read the stored SMTP password at a host of their choosing

THE SHAPE

SHAPE-032 · credential redirect

- A configuration editor redirects the endpoint a managed deputy delivers a stored secret to
- A secret the editor cannot read reaches a destination the editor controls
- Later reproduced across all domains



CASE 3 · HOW THE MODEL DECIDED IT WAS REAL

The reasonable customer test

“Would a reasonable customer be alarmed that a configuration editor who cannot read the stored SMTP password could redirect where the managed service delivers it — to a host the editor chose?”

No

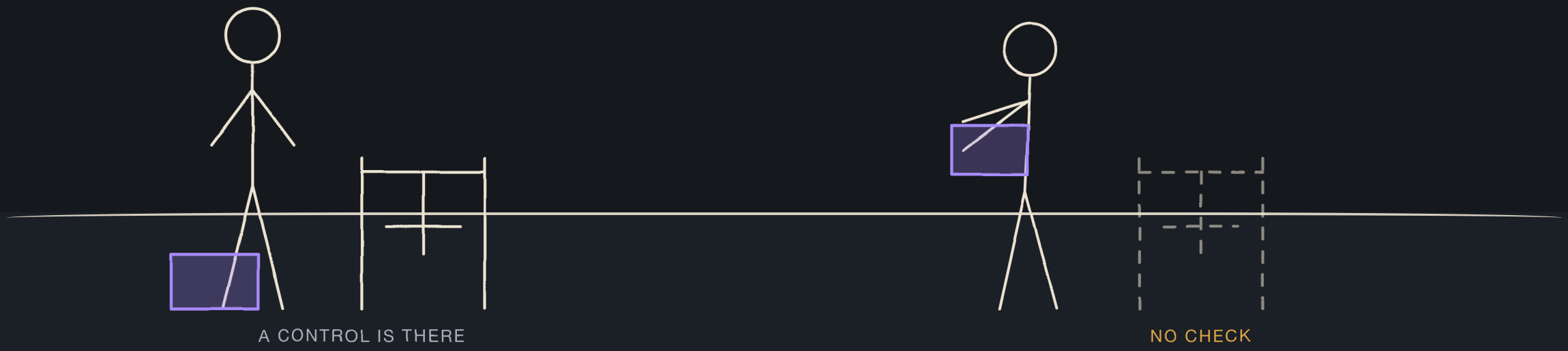
A control is in place, but the feature could be abused.

FEATURE ABUSE · NOT REPORTABLE

Yes

The control a customer would expect is missing.

INSECURE-BY-DESIGN FLAW · REPORTABLE



SHAPE-032: CREDENTIAL REDIRECT

One true positive. Then it farms.

1 · The first instance
A configuration change redirected where a managed service delivers a stored secret.

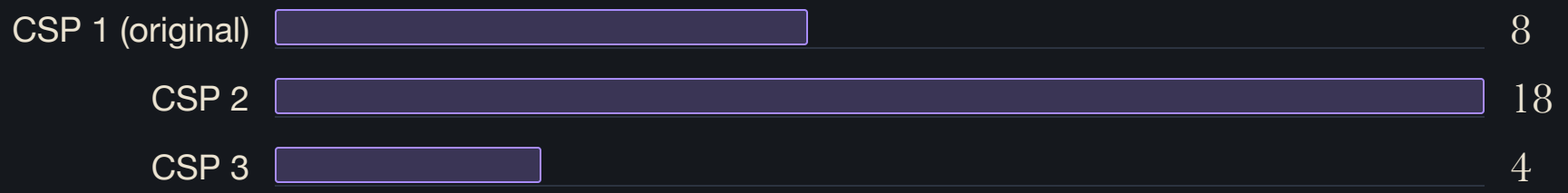
→

2 · Codified as a shape and a signal
Wrote SHAPE-032, and the signal for how to inspect an API for it.

→

3 · Farmed
The same shape across three cloud providers — the Managed Grafana finding you just saw was one of them.

30
filings from this one shape



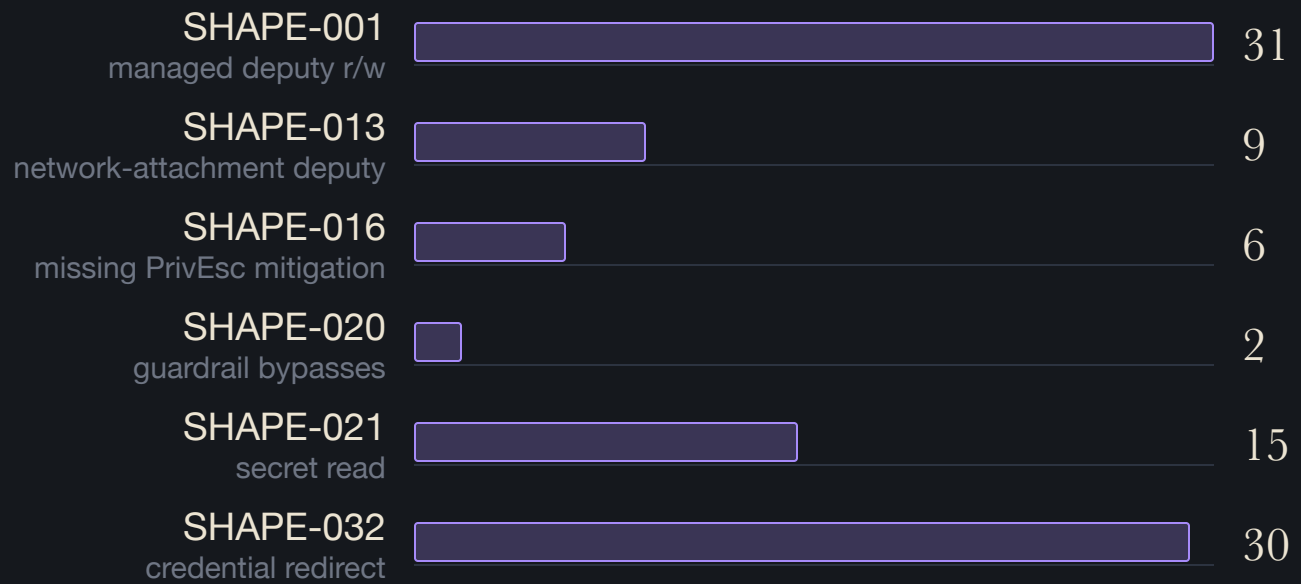
One catalogue of shapes and signals

36

vulnerability **shapes** in the register

40

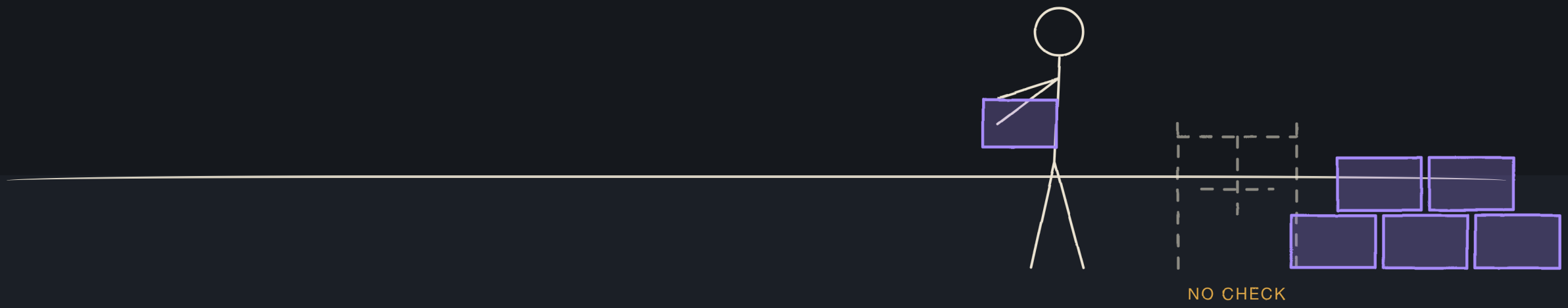
discovery **signals** — the API-doc clues that route to a shape



PRINCIPLE 8

Bounded blast radius for delegation

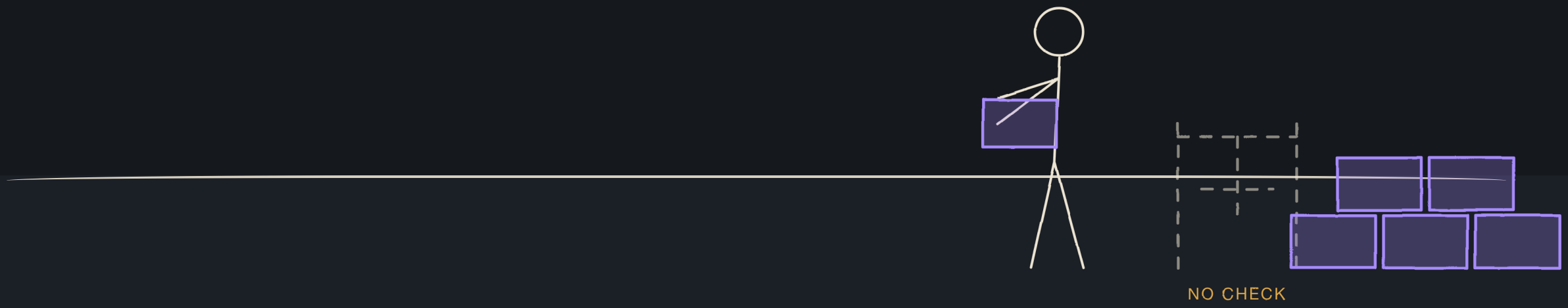
When one identity is allowed to act as another, that delegation must be bounded and explicitly authorized — a delegation nobody authorized is a design flaw.



Integration Connectors

GCP · b/529292612 | accepted

THE FINDING *connections.create and siblings*	Missing .actAs check allowing a Connectors editor to run as any service account in the project, resulting in privilege escalation
THE SHAPE *SHAPE-016 · missing PrivEsc mitigation*	A method binds a customer-managed identity as the run-as account without checking that the caller holds actAs on it.



WHERE THIS GOES NEXT

Nothing here is specific to the cloud

The constitution describes any platform where a provider-owned identity acts on a customer's behalf inside a shared system.

Other providers

I'm expanding this work into a fourth domain with a new adapter using the same principles.

Kubernetes

Managed add-ons, and the OIDC bridges between cluster and control plane, are all deputies to consider.

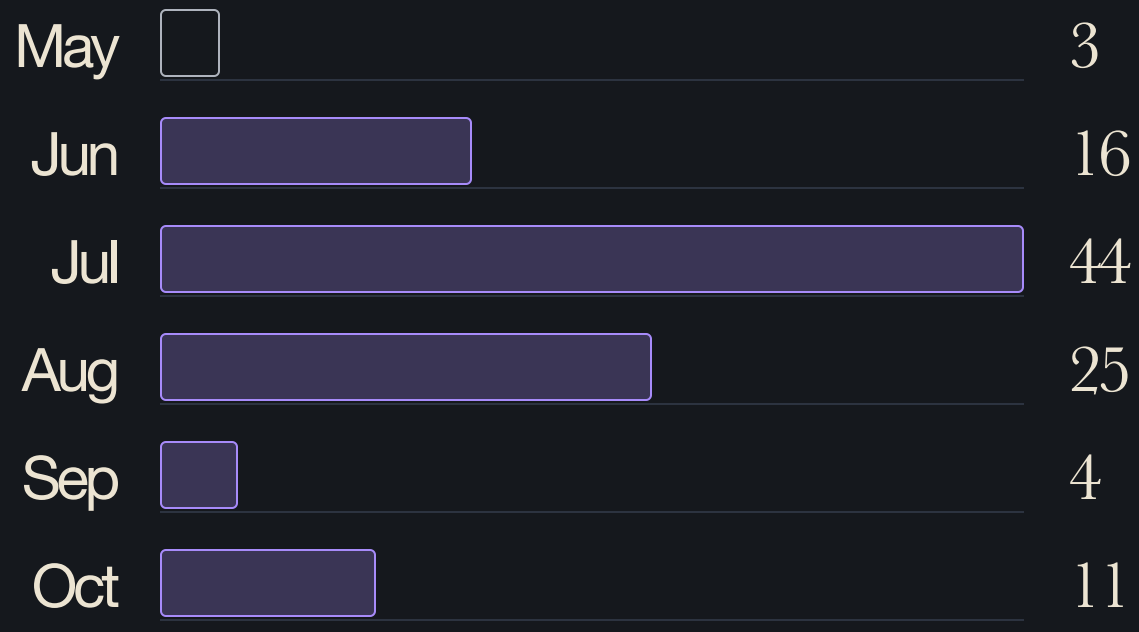
Any multi-tenant PaaS or SaaS

Consider all systems built on top of CSPs, offering tenancy to customers.



WHERE IT STANDS TODAY

This is not finished



filings per month

45

still in triage with the providers

awaiting triage · awaiting determination · in dispute

Four in ten of what's been filed is still open. I'll be at this for a while.

Your harness doesn't
need more scaffolding.
It needs a point of view.



kattraxler.cloud

Thanks

Kat Traxler

Security Research

kattraxler.cloud

[un]prompted

The AI Practitioner Conference